



**UAdeO**  
UNIVERSIDAD AUTÓNOMA DE OCCIDENTE

***Proyecto Final – Red  
Empresarial***

**Licenciatura:** Ingeniería en Seguridad Informática y  
Redes.

**Materia:** Seguridad de Redes.

**Profesor/a:** Jesús Alfonso Valdenegro.

**Unidad Académica:** Culiacán Rosales.

**4TO Semestre.**

**E305 ISIR**

**Matricula:** 24040227

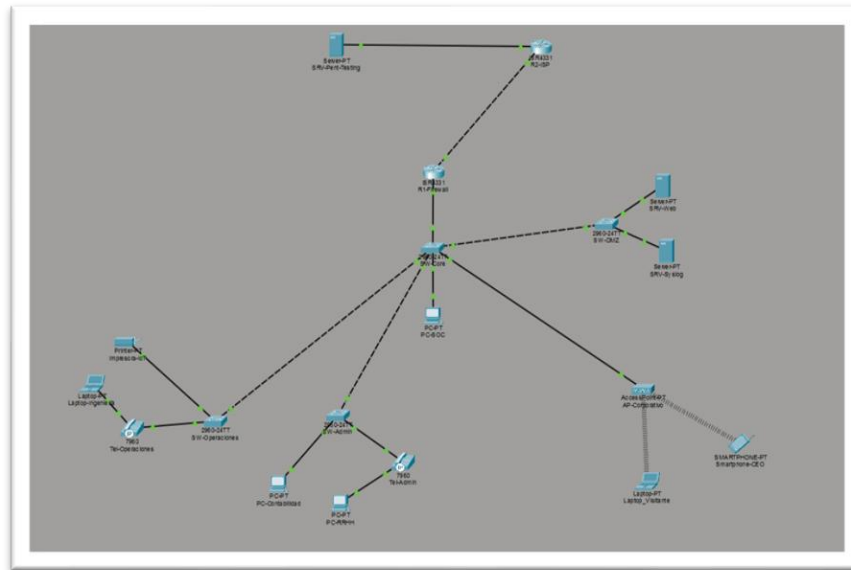
**Nombre:** Sebastián Salcedo Núñez.

**Fecha:** 06/JUNIO/2026

## Proyecto Final – Red Segura Empresarial

### *Arquitectura Base y Topología Física*

La infraestructura se diseña bajo un modelo jerárquico que optimiza el rendimiento y centraliza las políticas de seguridad. La topología física implementada en Cisco Packet Tracer se estructura a partir de los siguientes componentes interconectados:



- **Router de Borde (R1-Firewall):** Actúa como el Gateway de la organización, ejecutando las funciones de enrutamiento Inter-VLAN (Router-on-a-Stick), traducción de direcciones (PAT) y filtrado perimetral de paquetes mediante ACLs.
- **Switch de Distribución (SW-Core):** Centraliza el tráfico de la red interna. Conecta directamente con el router de borde a través de un enlace troncal, gestiona el acceso directo a los servidores de la Zona Desmilitarizada (DMZ) y distribuye la conectividad hacia los equipos de la periferia.
- **Switch de Acceso (SW-Admin):** Conectado al SW-Core. Provee conectividad directa a los endpoints del área administrativa (PCs) y a los teléfonos IP, aplicando segmentación a nivel de puerto.
- **Access Point (AP-Corporativo):** Conectado al SW-Core en un puerto de acceso dedicado para extender los servicios de red de forma inalámbrica bajo estrictos parámetros de autenticación.

*Segmentación Lógica y Direccionamiento (Capas 2 y 3)**Tabla de Direccionamiento y Segmentación de la Red*

| <b>VLAN ID</b> | <b>Nombre de la VLAN</b> | <b>Dirección de Red / Máscara</b> | <b>Gateway (Roas)</b> | <b>Propósito / Dispositivos</b>                            |
|----------------|--------------------------|-----------------------------------|-----------------------|------------------------------------------------------------|
| <b>10</b>      | Admin                    | 192.168.10.0 / 24                 | 192.168.10.1          | Área administrativa.<br>PCs y laptops corporativas.        |
| <b>20</b>      | VoIP                     | 192.168.20.0 / 24                 | 192.168.20.1          | Telefonía IP.<br>Aislamiento de tráfico SIP/RTP.           |
| <b>30</b>      | WiFi                     | 192.168.30.0 / 24                 | 192.168.30.1          | Red inalámbrica segura (Tráfico de usuarios WiFi).         |
| <b>50</b>      | DMZ                      | 192.168.50.0 / 24                 | 192.168.50.1          | Zona Desmilitarizada.<br>Servidores internos/públicos.     |
| <b>99</b>      | Mgmt (Gestión)           | 192.168.99.0 / 24                 | 192.168.99.1          | Gestión de equipos (Interfaces virtuales SVI de Switches). |

*Nota: Razón de la Segmentación de Dominios de Broadcast*

Las VLANs operan en la Capa 2 (Enlace de Datos) del modelo OSI. Al fragmentar el switch en múltiples dominios de broadcast lógicos, un ataque de envenenamiento de tablas MAC o saturación ARP (ARP Spoofing) iniciado en la VLAN 30 (WiFi) queda completamente aislado, impidiendo que el atacante intercepte el tráfico de la VLAN 10 (Admin).

*Mitigación de Ataques L2: VLAN Hopping y PortFast*

Los enlaces entre R1-Firewall, SW-Core y SW-Admin operan en modo troncal utilizando el protocolo de etiquetado IEEE 802.1Q. Para prevenir ataques de salto de VLAN (*VLAN Hopping*) por medio de doble etiquetado, se deshabilita la negociación DTP (Dynamic Trunking Protocol) y se modifica la VLAN nativa por defecto (VLAN 1) hacia una VLAN confinada y sin uso (VLAN 99).

Comandos del Bash en SW-Core:

- **SW-Core(config)# interface range GigabitEthernet0/1-2, FastEthernet0/1-2**
- **SW-Core(config-if-range)# switchport mode trunk**
- **SW-Core(config-if-range)# switchport nonegotiate**
- **SW-Core(config-if-range)# switchport trunk native vlan 99**

En las interfaces de acceso conectadas a hosts finales y al Access Point, se habilita la función PortFast de Spanning Tree Protocol (STP). Esto permite que el puerto transite inmediatamente al estado de Forwarding omitiendo los estados de Listening y Learning, previniendo caídas de sesión por temporización durante la solicitud DHCP y evitando vectores DoS basados en la inyección de BPDU falsificadas (complementado idealmente con bpduguard).

Comandos del Bash en SW-Core:

- **SW-Core(config)# interface FastEthernet0/3**
- **SW-Core(config-if)# switchport mode access**
- **SW-Core(config-if)# switchport access vlan 30**
- **SW-Core(config-if)# spanning-tree portfast**

### *Mitigación de Ataques L2: VLAN Hopping y PortFast*

Para optimizar el cableado estructurado sin comprometer la confidencialidad, los teléfonos IP y las PCs administrativas se conectan en cascada (*Daisy-Chaining*) sobre el mismo puerto físico del SW-Admin, manteniendo la separación estricta de tráfico a nivel de hardware.

#### Comandos Bash de SW - Admin:

- **SW-Admin(config)# interface FastEthernet0/1**
- **SW-Admin(config-if)# switchport mode access**
- **SW-Admin(config-if)# switchport access vlan 10**
- **SW-Admin(config-if)# switchport voice vlan 20**

Esta configuración fuerza al switch a etiquetar el tráfico de datos con el Tag ID 10 y el tráfico de voz con el Tag ID 20 de forma interna. Si un atacante conecta una PC comprometida e inicia un software de captura en modo promiscuo (como Wireshark), la tarjeta de red (NIC) del host ignorará el tráfico de la VLAN 20, impidiendo la interceptación pasiva de llamadas telefónicas corporativas (Eavesdropping).

### *Enrutamiento e Infraestructura de Servicios (Capa 3)*

#### *Router-on-a-Stick (RoaS)*

El enrutamiento entre las diferentes VLANs de la organización se centraliza en la interfaz física GigabitEthernet0/0/0 de R1-Firewall. Se crean subinterfaces lógicas para cada segmento, donde el router remueve el encabezado 802.1Q entrante, analiza la dirección IP de destino (Capa 3) y vuelve a etiquetar el paquete antes de retransmitirlo.

#### Comandos Bash R1 – Firewall:

- **R1-Firewall(config)# interface GigabitEthernet0/0/0.10**
- **R1-Firewall(config-subif)# encapsulation dot1Q 10**
- **R1-Firewall(config-subif)# ip address 192.168.10.1 255.255.255.0**

### *Automatización y Seguridad DHCP*

El enrutador perimetral actúa como servidor DHCP para la infraestructura interna. Se configuran exclusiones estrictas de direccionamiento para resguardar las IPs de gateways, switches y servidores, bloqueando la posibilidad de ataques de denegación de servicio por conflicto de IPs estáticas. Para la VLAN de Voz, se añade la **Opción 150**, indispensable para que los terminales telefónicos localicen por TFTP el servidor de llamadas (CME) y descarguen su archivo de configuración.

#### Comandos Bash R1 – Firewall:

- **R1-Firewall(config)# ip dhcp excluded-address 192.168.10.1 192.168.10.10**
- **R1-Firewall(config)# ip dhcp pool POOL\_VOIP**
- **R1-Firewall(dhcp-config)# network 192.168.20.0 255.255.255.0**
- **R1-Firewall(dhcp-config)# default-router 192.168.20.1**
- **R1-Firewall(dhcp-config)# option 150 ip 192.168.20.1**

### *Seguridad Perimetral, Control de Acceso y Criptografía (Capas 4 a 7)*

La seguridad perimetral se consolida en R1-Firewall mediante el uso de Listas de Control de Acceso (ACLs) Extendidas, inspeccionando campos de Capa 3 (IPs de origen/destino) y Capa 4 (Puertos TCP/UDP).

### *Arquitectura e Inviolabilidad de la DMZ*

Para mitigar el riesgo de movimientos laterales en caso de que el servidor web público sufra un compromiso (ej. explotación de vulnerabilidades de software o inyecciones web), se aplica la política de aislamiento perimetral. La regla prohíbe taxativamente que cualquier flujo de comunicación sea *iniciado* desde la DMZ hacia la LAN interna.

Comandos Bash para Asegurar el Aislamiento de la DMZ en R1 – Firewall:

- **R1-Firewall(config)# ip access-list extended FILTRADO\_DMZ**

Permitir administración SSH exclusiva desde la Red Admin al Servidor

- **R1-Firewall(config-ext-nacl)# permit tcp 192.168.10.0 0.0.0.255 host 192.168.50.10 eq 22**

Permitir tráfico público web externo (HTTP) hacia el Servidor

- **R1-Firewall(config-ext-nacl)# permit tcp any host 192.168.50.10 eq 80**

ACL DE AISLAMIENTO: Denegar cualquier otra interacción originada en la DMZ hacia la LAN

- **R1-Firewall(config-ext-nacl)# deny ip 192.168.50.0 0.0.0.255 192.168.10.0 0.0.0.255**

Aplicación inbound en la subinterfaz de la DMZ para descartar tráfico ilícito de inmediato

- **R1-Firewall(config)# interface GigabitEthernet0/0/0.50**
- **R1-Firewall(config-subif)# ip access-group FILTRADO\_DMZ in**

*Ocultamiento de Topología mediante PAT*

Para proteger el direccionamiento interno corporativo frente al escaneo externo, se implementa NAT con sobrecarga o PAT (Port Address Translation). Toda la infraestructura privada se traduce dinámicamente a la IP pública de la interfaz WAN (GigabitEthernet0/0/1). Al carecer de registros estáticos hacia la LAN, los atacantes externos no pueden iniciar conexiones directas hacia los hosts internos, sirviendo como una línea de defensa perimetral pasiva.

Comando Bash R1 – Firewall:

- **R1-Firewall(config)# ip nat inside source list 1 interface GigabitEthernet0/0/1 overload**

### *Hardening de Dispositivos y Criptografía de Administración*

Se mitigan los ataques de Hombre en el Medio (MitM) deshabilitando servicios inseguros en texto claro como Telnet (TCP 23) y HTTP (TCP 80). El acceso administrativo a la CLI de los dispositivos se restringe exclusivamente a SSHv2 (Capa 7), garantizando la Confidencialidad y la Integridad de las credenciales mediante criptografía asimétrica RSA con llaves de 1024 bits y autenticación local forzada.

#### Comandos Bash para la Administración Segura Mediante una Conexión SSH

- **R1-Firewall(config)# hostname R1-Firewall**
- **R1-Firewall(config)# ip domain-name empresa.local**
- **R1-Firewall(config)# crypto key generate rsa**

(ACLARACION) Longitud elegida: 1024 bits

- **R1-Firewall(config)# username admin privilege 15 secret CiscoSecure!**
- **R1-Firewall(config)# line vty 0 4**
- **R1-Firewall(config-line)# login local**
- **R1-Firewall(config-line)# transport input ssh**

### *Mecanismos de Protección en la Suite TCP/IP*

Para salvaguardar la disponibilidad de la red se analizan los protocolos criptográficos esenciales:

- **IPSec (Internet Protocol Security):** Opera en la Capa 3 (Red). Cifra y autentica cada paquete IP dentro de un túnel VPN corporativo (mediante protocolos como ESP y AH), protegiendo la interconexión de sucursales frente a la interceptación en internet.
- **SSL/TLS (Secure Sockets Layer / Transport Layer Security):** Opera en la Capa 4 (Transporte). Provee un canal cifrado de extremo a extremo para aplicaciones de Capa 7 (como HTTPS o VPNs SSL), protegiendo sesiones de usuario individuales basadas en certificados digitales x.509.



## *Implementaciones Conceptuales de Monitoreo y Defensa*

### *Sistemas de Detección y Prevención de Intrusos (IDS/IPS)*

- **NIDS (Network-based IDS):** Se ubica estratégicamente acoplado a un puerto SPAN (Switched Port Analyzer / Port Mirroring) en el switch SW-Core. El switch duplica de manera pasiva todo el tráfico de la DMZ (VLAN 50) y lo envía al puerto del sensor NIDS. Esto permite analizar firmas de ataques (como inyecciones SQL, escaneos de puertos o exploits) en tiempo real y de forma *Out-of-Band* (fuera de línea), garantizando que el análisis de seguridad no induzca latencia en la red de producción.
- **HIDS (Host-based IDS):** Monitoriza la actividad interna de un dispositivo final específico (servidor o endpoint). Analiza de manera directa los registros de auditoría del sistema operativo (logs), modificaciones no autorizadas en archivos críticos del sistema y llamadas al kernel, detectando intrusiones que los sistemas perimetrales basados en red no pueden visualizar debido al tráfico cifrado de extremo a extremo.

### *Seguridad Inalámbrica (WLAN) y Evolución de Protocolos*

El AP-Corporativo implementa seguridad rigurosa en la frecuencia de radio para evitar el acceso de intrusos a los recursos de la red interna:

#### *Configuración y Aseguramiento de la Red Inalámbrica (VLAN 30)*

Para la infraestructura inalámbrica extendida por el **AP-Corporativo**, se aplican políticas estrictas de control de acceso y segmentación para mitigar los riesgos inherentes al medio guiado por radiofrecuencia (aire):

- **Parámetros de la WLAN Corporativa:**
  - **SSID (Nombre de Red):** Red-Empresarial
  - **Autenticación y Cifrado: WPA2-Personal (AES).** Se descartan esquemas legados como WEP o WPA-TKIP debido a sus fallas matemáticas en los vectores de inicialización que permiten el descifrado pasivo de tráfico.
  - **Clave de Acceso (Simulación de Robustez):** CiscoSecure2026!

- **Segmentación de Usuarios Inalámbricos:** El tráfico asociado al SSID es inyectado directamente por el Access Point de manera etiquetada hacia la VLAN 30. A través de las directivas en R1-Firewall, se bloquea el acceso inalámbrico general hacia la red administrativa (VLAN 10) y la red de gestión (VLAN 99). Los dispositivos de usuarios (como el Smartphone-CEO o la Laptop\_Visitante) solo disponen de salida regulada hacia internet mediante PAT, mitigando el riesgo de que un endpoint infectado por malware realice escaneos o movimientos laterales contra la infraestructura core de la universidad.

El como han evolucionado los distintos protocolos de seguridad de WiFi ha sido constante a lo largo de los años:

- **WEP (Wired Equivalent Privacy):** Protocolo obsoleto y totalmente vulnerable. Utiliza el algoritmo de cifrado de flujo RC4 con vectores de inicialización (IV) extremadamente cortos (24 bits) que se transmiten en texto claro.
- **WPA (Wi-Fi Protected Access):** Este Implementó TKIP (Temporal Key Integrity Protocol) como solución temporal para solucionar las debilidades de WEP.
- **WPA2-Personal (Estándar Implementado):** Aplica el robusto algoritmo de cifrado simétrico AES (Advanced Encryption Standard) combinado con CCMP (Counter Mode Cipher Block Chaining Message Authentication Code Protocol).
- **WPA3:** El estándar más reciente de la industria. Reemplaza el intercambio de claves tradicional de WPA2 por el protocolo SAE (Simultaneous Authentication of Equals), anulando los ataques de fuerza bruta y diccionario fuera de línea (*offline dictionary attacks*) y blindando las redes inalámbricas modernas.

## Anexos de Pruebas e Investigaciones

### *Anexos de Validación de Seguridad y Bitácoras de Monitoreo*

Para certificar la resiliencia y el correcto funcionamiento de las políticas de seguridad perimetral implementadas en la arquitectura de red, se ejecutó un plan de pruebas ofensivas y de auditoría interna utilizando el nodo externo SRV-Pent-Testing (actuando como estación de auditoría ofensiva/Kali Linux con dirección 8.8.8.10/24) y los servidores dedicados de la Zona Desmilitarizada (DMZ).

### *Plan de Pruebas Ofensivas y Pentesting Controlado*

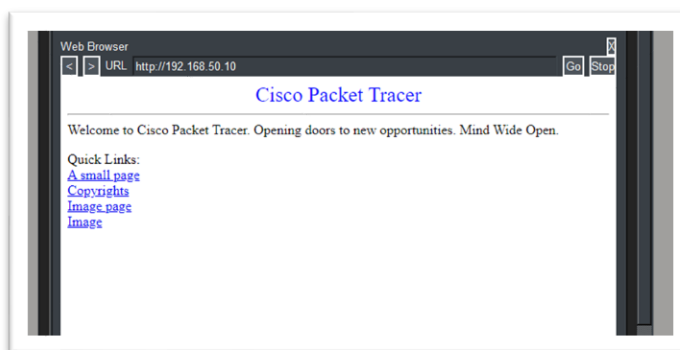
#### *Simulación de la Fase de Reconocimiento (Scripting de Auditoría)*

La auditoría comenzó simulando la fase inicial de footprinting o reconocimiento externo para mapear el perímetro de la organización. Desde el editor de texto de la estación de pruebas, se estructuró un script en Bash ejecutable que automatiza el escaneo SYN sigiloso (-sS) mediante la herramienta Nmap, apuntando hacia los puertos críticos de administración y servicios públicos del Gateway corporativo (200.100.10.1).



#### *Validación de Acceso Público a los Servicios de la DMZ (Capa de Aplicación - HTTP)*

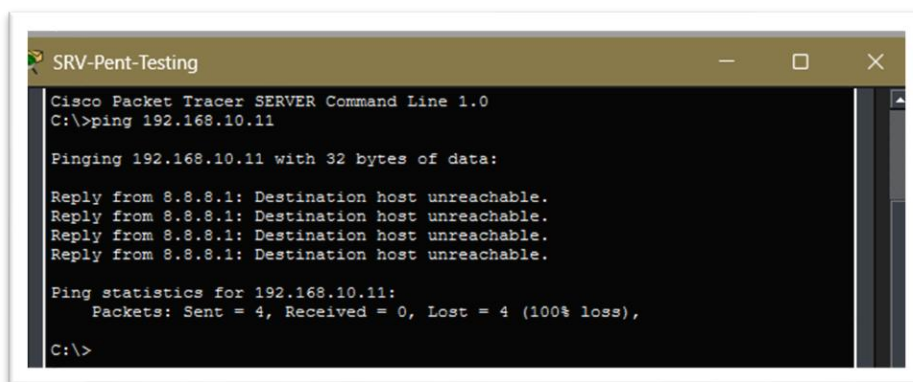
Se verificó el cumplimiento de las políticas de alta disponibilidad del negocio. Al iniciar una sesión de navegación web desde la terminal externa hacia la dirección IP del servidor web de la zona desmilitarizada



(http://192.168.50.10), la petición HTTP orientada a conexiones en el puerto TCP 80 fue procesada de manera exitosa.

*Bloqueo de Intrusión hacia la Red Administrativa (Aislamiento WAN-LAN)*

Para simular un intento de intrusión no autorizado o escaneo destructivo de Capa 3, la estación externa ejecutó ráfagas de paquetes de diagnóstico ICMP (ping) orientadas hacia la dirección IP privada del núcleo corporativo correspondiente a la PC-Contabilidad (192.168.10.11).



```
SRV-Pent-Testing
Cisco Packet Tracer SERVER Command Line 1.0
C:\>ping 192.168.10.11

Pinging 192.168.10.11 with 32 bytes of data:

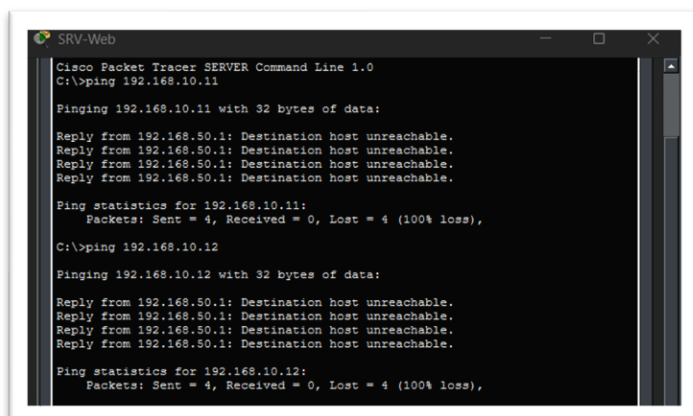
Reply from 8.8.8.1: Destination host unreachable.
Reply from 8.8.8.1: Destination host unreachable.
Reply from 8.8.8.1: Destination host unreachable.
Reply from 8.8.8.1: Destination host unreachable.

Ping statistics for 192.168.10.11:
    Packets: Sent = 4, Received = 0, Lost = 4 (100% loss),

C:\>
```

*Mitigación de Movimientos Laterales desde la DMZ*

Me encargue de evaluar el escenario de riesgo crítico en el cual un atacante logra explotar una vulnerabilidad web (vía inyección de código) y compromete la integridad del **SRV-Web** (192.168.50.10). Actuando desde la terminal de comando de dicho servidor comprometido, se intentaron realizar pings de reconocimiento y pivoteo hacia los hosts de la red interna administrativa (192.168.10.11 y 192.168.10.12).



```
SRV-Web
Cisco Packet Tracer SERVER Command Line 1.0
C:\>ping 192.168.10.11

Pinging 192.168.10.11 with 32 bytes of data:

Reply from 192.168.50.1: Destination host unreachable.
Reply from 192.168.50.1: Destination host unreachable.
Reply from 192.168.50.1: Destination host unreachable.
Reply from 192.168.50.1: Destination host unreachable.

Ping statistics for 192.168.10.11:
    Packets: Sent = 4, Received = 0, Lost = 4 (100% loss),

C:\>ping 192.168.10.12

Pinging 192.168.10.12 with 32 bytes of data:

Reply from 192.168.50.1: Destination host unreachable.
Reply from 192.168.50.1: Destination host unreachable.
Reply from 192.168.50.1: Destination host unreachable.
Reply from 192.168.50.1: Destination host unreachable.

Ping statistics for 192.168.10.12:
    Packets: Sent = 4, Received = 0, Lost = 4 (100% loss),
```

## *Implementación y Validación de VPN – Tunnel GRE*

Me encargue de implementar una VPN de capa 3 basada en el protocolo GRE (Generic Routing Encapsulation) en el Gateway principal corporativo.

### *Parámetros de Direccionamiento Lógico (Actualización de Capa 3)*

Para la integración del enlace virtual seguro dentro de la infraestructura jerárquica, se asignó una subred dedicada con máscara de subred fija (/30), la cual se acopla al esquema general de segmentación de la organización de la siguiente manera:

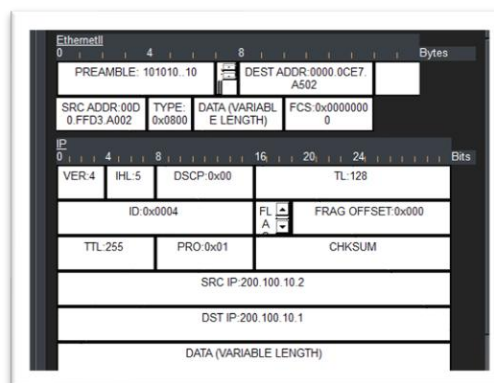
- **Interfaz Virtual:** Tunnel 0
- **Identificador de Red:** 10.0.0.0 / 30
- **Dirección IP Asignada (R1-Firewall):** 10.0.0.1
- **Máscara de Subred:** 255.255.255.252

**Propósito del Enlace:** Establecimiento de un canal lógico privado punto a punto sobre la infraestructura pública de internet (R2-ISP) para transporte seguro de datos.

### *Validación de Funcionamiento mediante Inspección Forense de PDU*

Para certificar de manera empírica que el tráfico es interceptado y encapsulado correctamente por la VPN antes de abandonar el perímetro de la organización, se activó el Modo Simulación en Cisco Packet Tracer filtrando exclusivamente las tramas de control del protocolo ICMP.

Se capturó la Unidad de Datos de Protocolo (PDU) de diagnóstico en tránsito sobre el núcleo del proveedor de servicios de internet para inspeccionar sus cabeceras lógicas (*Outbound PDU Details*).



## *Auditoría y Persistencia de Eventos en el Sistema de Monitoreo*

### *Inyección Controlada de Alertas en el Gateway Perimetral*

Para verificar que el sistema de telemetría y monitoreo interno responde ante anomalías o cambios de estado físicos, se ingresó a la CLI del enrutador de borde R1-Firewall. Dentro del modo de configuración de subinterfaz, se forzó de manera intencional una caída administrativa temporal (shutdown y no shutdown) en los canales troncales de comunicación.

```

R1-Firewall(config)#interface GigabitEthernet0/0/0.10
R1-Firewall(config-subif)#shutdown

R1-Firewall(config-subif)#
%LINK-5-CHANGED: Interface GigabitEthernet0/0/0.10, changed state to
administratively down

%LINEPROTO-5-UPDOWN: Line protocol on Interface GigabitEthernet0/0/0.10,
changed state to down

R1-Firewall(config-subif)#no sh
R1-Firewall(config-subif)#no shutdown

R1-Firewall(config-subif)#
%LINK-3-UPDOWN: Interface GigabitEthernet0/0/0.10, changed state to down

%LINEPROTO-5-UPDOWN: Line protocol on Interface GigabitEthernet0/0/0.10,
changed state to up

R1-Firewall(config-subif)#end
R1-Firewall#
%SYS-5-CONFIG_I: Configured from console by console

R1-Firewall#
  
```

### *Centralización y Persistencia de Bitácoras Forenses (Syslog UDP 514)*

Finalmente, se accedió al entorno gráfico del servidor centralizado SRV-Syslog (192.168.50.12) en la DMZ para validar la recepción de las alertas. Se comprobó la existencia de registros detallados enviados de forma automática por el Gateway (192.168.50.1).

| Service | Time | HostName     | Message            |
|---------|------|--------------|--------------------|
| 1       |      | 192.168.50.1 | %SYS-5-CONFIG_I... |
| 2       |      | 192.168.50.1 | %LINEPROTO-5-...   |
| 3       |      | 192.168.50.1 | %LINK-3-UPDOWN:... |
| 4       |      | 192.168.50.1 | %LINEPROTO-5-...   |
| 5       |      | 192.168.50.1 | %LINK-5-CHANGE...  |

### *Expansión de la Superficie de Ataque: Redes Personales (WPAN) e IoT*

El despliegue de tecnologías fuera del ecosistema puramente cableado e inalámbrico tradicional amplía drásticamente la superficie de exposición de la organización ante agentes de amenaza locales.

- **Bluetooth (802.15.1):** Tecnología de red de área personal inalámbrica (WPAN) que opera en la banda libre de 2.4 GHz. En un contexto empresarial, los endpoints están expuestos a vectores de ataque específicos como:
  - **Bluejacking:** Envío de mensajes de texto masivos no solicitados a dispositivos vulnerables dentro del rango de cobertura, utilizado como vector inicial de ingeniería social.
  - **Bluesnarfing:** Acceso no autorizado y robo de información crítica (contactos, correos, calendarios y archivos de datos) aprovechando fallas de autenticación en el protocolo de intercambio de objetos (OBEX).
  - **Blueborne:** Un conjunto de vulnerabilidades críticas que permiten a un atacante tomar el control total de dispositivos móviles o laptops de forma remota, sin requerir interacción del usuario ni emparejamiento previo.
- **ZigBee (802.15.4):** Protocolo de comunicación inalámbrico de alta eficiencia y bajo consumo de energía, muy extendido en sistemas de automatización industrial y domótica. Su debilidad estructural principal reside en su arquitectura de gestión de llaves: durante la asociación inicial de un nuevo sensor a la red, la clave maestra de cifrado corporativa (*Network Master Key*) se transmite habitualmente en texto claro por el espectro radioeléctrico. Un atacante equipado con hardware de bajo costo (como un transceptor de radio SDR) puede capturar la llave en el aire y descifrar la totalidad de las comunicaciones del entorno físico de la empresa.

- **Vulnerabilidades y Riesgos en Dispositivos IoT:** Los dispositivos de Internet de las Cosas (como cámaras de vigilancia IP, sensores inteligentes o termostatos conectados) representan uno de los eslabones más débiles de la seguridad de la infraestructura por tres razones principales:
  1. **Credenciales por Defecto:** Gran cantidad de dispositivos traen contraseñas codificadas de fábrica no modificables en su firmware, sirviendo de vector principal para el reclutamiento masivo de botnets dirigidas a ataques distribuidos de denegación de servicio (DDoS), como el histórico caso de la botnet *Mirai*.
  2. **Ausencia de Ciclos de Vida de Parches:** Hardware económico con sistemas operativos Linux embebidos que carecen de mecanismos automatizados para actualizar su firmware frente a vulnerabilidades descubiertas.
  3. **Transmisión Insegura:** Envío de telemetría y datos de control corporativos hacia servidores de la nube a través de protocolos legados sin cifrado (HTTP plano, MQTT inseguro).
- **Medidas de Protección:** Aislar obligatoriamente todo el ecosistema de dispositivos IoT dentro de una VLAN dedicada y restringida, aplicar listas de control de acceso que impidan su comunicación hacia el segmento administrativo LAN, y forzar la renovación completa de contraseñas de fábrica antes del despliegue en producción.



## *Protocolos de Señalización VoIP y Amenazas Asociadas*

La convergencia de voz y datos sobre la misma infraestructura exige un profundo análisis de los estándares de señalización (Capa 7) que gobiernan las sesiones multimedia y sus vulnerabilidades asociadas.

- **Análisis de Protocolos de Voz sobre IP:**
  - **SIP (Session Initiation Protocol):** Protocolo estandarizado por la IETF basado en texto legible por humanos (altamente similar a HTTP) que opera de forma generalizada sobre los puertos UDP/TCP 5060 y 5061. Se encarga exclusivamente del establecimiento, mantenimiento y finalización de las sesiones multimedia, delegando el flujo de audio en tiempo real al protocolo complementario RTP (Real-Time Transport Protocol). Al carecer inherentemente de cifrado, la señalización SIP es vulnerable a manipulación si no se implementa su versión segura cifrada con TLS (SIPS).
  - **H.323:** Una suite de protocolos de la ITU-T para comunicaciones de voz y video en red. A diferencia de SIP, H.323 se basa en una arquitectura de codificación binaria rígida, monolítica y compleja. Su diseño dificulta considerablemente el paso a través de mecanismos NAT y Firewalls perimetrales, considerándose hoy en día una tecnología heredada (*legacy*).
  - **MGCP (Media Gateway Control Protocol):** Protocolo que implementa un diseño de control centralizado basado en un modelo maestro-esclavo. En esta arquitectura, una entidad inteligente centralizada (Call Agent o controlador) envía directrices y comandos explícitos a pasarelas de voz descentralizadas y simplificadas (Media Gateways) para conectar los flujos telefónicos.
- **Amenazas Comunes en Infraestructuras VoIP:**
  - *Escucha Activa (Eavesdropping):* Captura maliciosa de los flujos de paquetes RTP que transportan el flujo de datos de audio sin cifrar. Con acceso al canal, herramientas de auditoría pueden reensamblar automáticamente los paquetes UDP y exportar la conversación íntegra en formatos de audio estándar.

- **Suplantación de Identidad (VoIP Spoofing):** Inyección de mensajes de señalización falsificados (SIP INVITE o REGISTER) para secuestrar el registro de una extensión telefónica legítima, desviando llamadas confidenciales hacia terminales maliciosos o cometiendo fraude de identidad telefónica (Caller ID Spoofing).
- **Ataques de Aplicación y Fraude Tarifario (Toll Fraud):** Explotación de vulnerabilidades de desbordamiento de búfer o configuraciones deficientes de control de acceso en las centralitas PBX o en el software de gestión del router (Cisco CME). Los atacantes externos aprovechan estas brechas para enrutar llamadas internacionales de alto costo a través de las troncales telefónicas de la empresa, generando perjuicios financieros severos.

### *Redes Inalámbricas Emergentes: MANET y WSN*

El desarrollo de entornos operacionales dinámicos o industriales ha impulsado arquitecturas inalámbricas de naturaleza descentralizada, las cuales carecen de perímetros tradicionales definidos.

- **MANET (Mobile Ad-Hoc Networks):** Redes inalámbricas descentralizadas integradas por nodos móviles que poseen la capacidad de autoconfigurarse dinámicamente y en tiempo real, operando de manera autónoma sin requerir una infraestructura fija o enrutadores centralizados.
- **WSN (Wireless Sensor Networks):** Redes inalámbricas conformadas por una vasta cantidad de microsensores espacialmente distribuidos y autónomos. Su función exclusiva es recopilar datos físicos o ambientales (ej. telemetría, presión, vibración, flujos industriales) y transmitir esta información de forma colaborativa a través de saltos de red inalámbricos hasta alcanzar un nodo central recolector o pasarela (Sink/Gateway).
- **Vulnerabilidades Estructurales de Redes Emergentes:** Debido a la ausencia de un punto central de control y fiscalización de tráfico, estas arquitecturas inalámbricas distribuidas enfrentan vectores de ataque críticos:

- **Ataque de Agujero Negro (Blackhole Attack):** Ocurre cuando un nodo malicioso se introduce en la red MANET e interviene de manera fraudulenta el protocolo de enrutamiento dinámico ad-hoc. El nodo comprometido emite anuncios falsos declarando poseer de forma constante el camino más óptimo, directo y corto hacia cualquier nodo de destino. Al lograr que la totalidad del tráfico circundante de la red sea direccionado hacia él, el atacante intercepta los paquetes y los descarta silenciosamente (drops), aislando por completo la comunicación de la infraestructura sin dejar rastro en los sistemas tradicionales.
- **Ataque de Privación de Sueño (Sleep Deprivation Attack):** Las redes de sensores WSN están integradas por hardware microscópico y de bajo costo que depende de pequeñas baterías de energía limitada, diseñadas para operar durante años alternando ciclos de actividad con estados prolongados de bajo consumo o suspensión profunda (Sleep Mode). En este ataque, el agresor bombardea al nodo de manera ininterrumpida con peticiones de comunicación basura o tramas de control formalmente válidas, pero totalmente innecesarias. Al procesar estas solicitudes falsas, el microcontrolador del sensor se ve forzado a permanecer permanentemente en su estado activo de máximo consumo energético, agotando por completo la batería del hardware en cuestión de horas y generando una denegación de servicio física distribuida e irreversible.